Security_Architecture_Standard

Technical Standard

保险公司 技术开发部

Contents

Security Architecture Standard

1. Overview

This document defines the security architecture standards for the insurance technology platform, covering network security, application security, data security, identity and access management, and security operations. References include MLPS 2.0, ISO 27001, and PCI DSS.

2. Security Principles

1. **Defense in Depth**: Multi-layer protection across network, host, application, and data
2. **Least Privilege**: Need-to-know authorization, default deny
3. **Shift Left**: Security embedded from development phase (DevSecOps)
4. **Data Classification**: Graded protection based on sensitivity
5. **Continuous Monitoring**: Real-time detection and response
6. **Compliance First**: Regulatory compliance is a hard requirement

3. Data Classification

Level	Definition	Examples	Protection
L4 Top Secret	Severe legal /financial damage	Bank card, passwords, biometrics	Encrypted store+transit, audited access
L3 Sensitive	Moderate risk	ID number, phone, policy details	Encrypted store, need-to-know
L2 Internal	Internal use only	Employee ID, rate tables	Internal network isolation
L1 Public	Publicly shareable	Product info, company address	No special requirements

4. Application Security

4.1 Authentication & Authorization

- Unified authentication: OAuth 2.0 / OIDC
- SSO: SAML 2.0 / CAS support
- MFA: Mandatory for admin consoles and internal networks
- API Auth: JWT + Scope-based authorization
- Fine-grained: RBAC / ABAC permission model

4.2 API Security

- Full HTTPS, TLS 1.2+
- Request signing (HMAC-SHA256)
- Anti-replay: Timestamp + Nonce
- Rate limiting: Per API Key and application
- Response auto-masking for sensitive fields

4.3 Input Validation

- Server-side parameter validation for all inputs

- Injection protection: SQL/NoSQL/XSS/command injection
- File upload: Whitelist extensions, size limits, content scanning
- ORM + prepared statements, no raw SQL concatenation

5. Network Security

Zone	Isolation	Access Control
Internet	Public	WAF + CDN + Anti-DDoS
DMZ	Demilitarized	Reverse proxy + API Gateway
Application	Internal	mTLS between services
Data	Highest isolation	DB whitelist + proxy
Management	Bastion host	Session recording + audit

6. Data Security

6.1 Encryption

- Transport: Full TLS 1.3
- Storage: AES-256 at rest
- Field-level: Application-layer encryption for sensitive data
- Key management: Centralized KMS, 90-day rotation

6.2 Data Masking

Type	Method	Example
Phone	Middle 4 hidden	138****1234
ID Number	First 6 last 4	110101****1234
Bank Card	First 4 last 4	6222****5678
Name	First char + *	J**

6.3 Audit Logging

- All data access recorded
- Logs are immutable and non-deletable
- Retention ≥ 180 days
- Content: Operator, IP, Object, Action, Timestamp

7. DevSecOps

Phase	Activity	Tools
Requirements	Threat modeling	STRIDE
Coding	SAST	SonarQube / Fortify
Build	Dependency scan	Snyk / Trivy
Testing	DAST	OWASP ZAP
Deploy	Container scan	Trivy / Clair
Runtime	Monitoring	WAF + RASP + SIEM

8. Security Incident Response

8.1 Incident Classification

Level	Definition	Response Time	Escalation
P0	Core service breach or data leak	Immediate	CEO + Security Lead
P1	Major attack, no data leak	30min	Security Lead
P2	General security incident	2h	Security Team
P3	Low-risk alert	24h	Duty officer

8.2 Response Flow

```
Detect → Confirm → Isolate → Forensics → Remediate → Postmortem
```

9. Compliance Mapping

Regulation	Controls	Verification
MLPS 2.0 Tier 3	All standards above	MLPS assessment
PIPL	Data classification + masking + consent	Privacy assessment
C-ROSS	Data integrity	Internal audit
Insurance Law	Policy data immutability	Blockchain / digital signatures